

Manual 18 — Implementación controlada de GLBA / Regla de Salvaguardas de la FTC

Edición controlada es-419 — borrador de localización

****Orden de serie:**** 18

****Límite regulatorio:**** Esta edición es guía de implementación. No reproduce texto regulatorio protegido, no constituye asesoría legal y no amplía la jurisdicción de la FTC más allá de las organizaciones sujetas a la Regla de Salvaguardas. Deben mantenerse separadas las capas estatutaria, regulatoria, de orientación oficial y de práctica organizacional.

1. Propósito, alcance y capas regulatorias

Establecer un programa repetible para implementar y evidenciar salvaguardas para información de clientes cubierta. Mantener un mapa de fuentes que diferencie el contexto estatutario de GLBA, los requisitos de 16 CFR Parte 314, las enmiendas y fechas de vigencia de la FTC, la orientación oficial de la FTC y las decisiones internas de control. Evidencia: memorando de aplicabilidad, registro de fuentes, inventario de controles y confirmación anual de alcance. Prueba: verificar que cada afirmación regulatoria sustantiva sea trazable a la capa correcta.

2. Aplicabilidad a instituciones financieras y jurisdicción

Determinar si la organización es una institución financiera para efectos de la Regla de Salvaguardas de la FTC y si otro regulador de GLBA gobierna la actividad. Documentar actividades, exenciones, regulador responsable, límites de entidad y disparadores de revisión legal. Evidencia: análisis de aplicabilidad y matriz de reguladores. Reevaluar tras fusiones, nuevos productos, cambios de licencia o nueva orientación regulatoria.

3. Alcance de información de clientes e inventario de datos

Inventariar la información de clientes y los sistemas que la recopilan, procesan, transmiten o almacenan. Mapear flujos, repositorios, interfaces, respaldos, endpoints, servicios SaaS y terceros. Asignar propietarios y clases de retención. Evidencia: inventario de datos, diagramas de flujo, registro de sistemas y vínculo con registros de tratamiento. Probar integridad contra herramientas de descubrimiento, contratos e inventarios de arquitectura.

4. Gobierno y responsabilidad del individuo calificado

Designar al individuo calificado responsable y definir autoridad, escalamiento, suplencias, presupuesto, obligaciones de reporte e interfaces con privacidad, legal, auditoría, riesgo y tecnología. Evidencia: estatuto, descripción de rol, RACI y actas. Probar que la autoridad asignada sea operativa y no meramente nominal.

5. Programa escrito de seguridad de la información

Mantener un programa escrito proporcional al tamaño, complejidad, actividades y sensibilidad de la información de clientes. Conectar gobierno, evaluación de riesgos,

salvaguardas, monitoreo, respuesta a incidentes, supervisión de proveedores y reportes. Evidencia: programa aprobado, historial de revisiones, estándares vinculados y propietarios de controles. Revisar al menos anualmente y después de cambios materiales.

6. Metodología de evaluación de riesgos

Usar una metodología documentada para identificar riesgos internos y externos previsible, evaluar probabilidad e impacto y determinar si las salvaguardas existentes son suficientes. Definir puntuación, criterios de aceptación, evidencia y disparadores de reevaluación. Evidencia: metodología, registro de riesgos y decisiones de tratamiento. Probar repetibilidad comparando sistemas similares.

7. Tratamiento de riesgos y selección de salvaguardas

Convertir hallazgos de riesgo en salvaguardas preventivas, detectivas, correctivas y de recuperación. Registrar objetivo de control, propietario, estado, fuente de evidencia, riesgo residual, fecha objetivo y manejo de excepciones. Evidencia: plan de tratamiento y matriz de controles. Probar que riesgos significativos tengan tratamiento explícito o aceptación formal.

8. Inventario de activos y sistemas

Mantener inventarios autoritativos de hardware, software, activos virtuales, servicios en nube, aplicaciones críticas, componentes de red y repositorios en alcance. Incluir propietario, entorno, criticidad, estado de ciclo de vida y relevancia para información de clientes. Evidencia: conciliación CMDB/inventario. Probar activos huérfanos o no administrados.

9. Clasificación y manejo de datos

Definir requisitos de manejo para información de clientes durante recopilación, uso, almacenamiento, transmisión, intercambio, archivo y destrucción. Alinear clasificación con acceso, cifrado, enmascaramiento, DLP y retención. Evidencia: estándar de clasificación, conjuntos etiquetados y procedimientos. Probar almacenes y transferencias de muestra.

10. Gestión de identidades y accesos

Aplicar privilegio mínimo, acceso basado en roles o atributos, provisión y baja oportunas, revisiones periódicas y controles sólidos de altas-cambios-bajas. Evidencia: solicitudes, aprobaciones, revisiones y registros de terminación. Probar cuentas inactivas, excesivas, compartidas o no autorizadas.

11. Acceso privilegiado y autenticación

Restringir y monitorear identidades privilegiadas. Usar controles de autenticación fuertes apropiados al entorno, incluida autenticación multifactor cuando corresponda por requisito o riesgo. Separar cuentas administrativas y estándar. Evidencia: logs PAM, inventario privilegiado, cobertura MFA y registros de emergencia. Probar rutas privilegiadas y revisión de accesos de emergencia.

12. Cifrado y gestión de claves

Proteger información de clientes en tránsito y reposo con controles criptográficos apropiados o protección compensatoria formalmente documentada cuando se permita y justifique.

Gestionar generación, almacenamiento, rotación, revocación, respaldo, acceso y destrucción de claves. Evidencia: configuraciones, inventario de claves y excepciones. Probar endpoints, bases de datos, respaldos e interfaces representativas.

13. Configuración segura y control de cambios

Establecer líneas base seguras, responsables de configuración, flujos de aprobación, segregación de funciones, rollback y revisión de cambios de emergencia. Evidencia: estándares, escaneos, tickets y aprobaciones. Probar deriva y cambios no autorizados.

14. Gestión de vulnerabilidades

Identificar, priorizar, remediar y verificar vulnerabilidades según riesgo. Definir cobertura de escaneo, escaneo autenticado, relación severidad-SLA, criterios de excepción y escalamiento. Evidencia: reportes, tickets y excepciones. Probar vulnerabilidades vencidas y patrones recurrentes.

15. Desarrollo seguro y controles de aplicaciones

Integrar seguridad en requisitos, diseño, desarrollo, pruebas, despliegue y mantenimiento de aplicaciones que manejan información de clientes. Incluir revisión de código, dependencias, secretos, modelado de amenazas, pruebas de seguridad y aprobación de liberaciones. Evidencia: registros SDLC, SAST/DAST, reportes de dependencias y gates de liberación.

16. Registro, monitoreo y detección de anomalías

Recolectar y proteger logs necesarios para detectar acceso no autorizado, uso indebido, actividad anómala, fallas de control e incidentes. Definir sincronización de tiempo, retención, responsables de alertas, escalamiento y afinamiento de casos de uso. Evidencia: estándar de logging, cobertura SIEM, alertas y configuración de retención. Probar detección extremo a extremo.

17. Respuesta a incidentes y escalamiento

Mantener procedimientos de identificación, triage, contención, erradicación, recuperación, preservación de evidencia, comunicaciones y mejora posterior. Asignar responsabilidad sobre decisiones de notificación legal y regulatoria. Evidencia: plan, ejercicios, incidentes y lecciones aprendidas. Probar con ejercicios de mesa sobre compromiso de información de clientes.

18. Flujo de decisión para eventos de notificación a la FTC

Mantener un flujo documentado para eventos que potencialmente cumplan el límite de notificación de la Regla de Salvaguardas. Preservar el límite actualmente verificado: análisis de adquisición sin autorización de información de clientes no cifrada, umbral aplicable de al menos 500 consumidores y requisito de notificación actualmente verificado de no más tarde de 30 días. No generalizar estas condiciones fuera del contexto de la regla de la FTC. Evidencia: hoja de decisión, revisión legal, base del conteo de consumidores y registro de notificación. Revalidar el texto regulatorio vigente antes de liberar y ante cada incidente relevante.

19. Interfaces con continuidad y resiliencia

Identificar dependencias entre salvaguardas y continuidad, incluidas identidad, logging, gestión de claves, respaldos seguros, comunicaciones alternativas y secuencia de recuperación. Evidencia: vínculo BIA, planes y ejercicios. Probar que la recuperación no omita controles de seguridad sin autorización de emergencia documentada.

20. Debida diligencia de proveedores

Evaluar proveedores que reciban, mantengan, procesen o accedan a información de clientes. Revisar capacidad de seguridad, evidencia de controles, incidentes, resiliencia, subcontratación y concentración. Evidencia: paquete de debida diligencia, calificación, aprobaciones y compromisos de remediación.

21. Salvaguardas contractuales y supervisión

Usar disposiciones contractuales apropiadas para exigir salvaguardas y permitir supervisión. Rastrear obligaciones de seguridad, términos de notificación, derechos de auditoría/evidencia, devolución o destrucción de datos y requisitos de subcontratistas. Evidencia: contratos, registro de obligaciones y calendario de revisión. Probar proveedores seleccionados contra obligaciones vigentes.

22. Nube y responsabilidad compartida

Mapear salvaguardas entre responsabilidades del proveedor y del cliente para IaaS, PaaS y SaaS. Documentar identidad, logging, cifrado, configuración, respaldo, red e incidentes. Evidencia: matriz de responsabilidad compartida, configuración de nube y aseguramiento del proveedor. Probar brechas creadas por supuestos incorrectos.

23. Seguridad de la fuerza laboral y capacitación

Implementar concientización y capacitación especializada según rol para administradores, desarrolladores, respondedores, gestores de proveedores y otros roles de alto riesgo. Evidencia: currículo, finalización, mapeo de roles y ejercicios. Probar cobertura y efectividad con métricas adecuadas.

24. Salvaguardas físicas

Proteger instalaciones, dispositivos, medios y áreas restringidas mediante controles de acceso, visitantes, ambiente, almacenamiento seguro y disposición proporcional al riesgo. Evidencia: logs, registros de visitantes, evaluaciones y manejo de medios. Probar revocación y controles de áreas restringidas.

25. Retención y eliminación segura de datos

Definir periodos de retención según requisitos legales, regulatorios, contractuales, operativos y de riesgo; eliminar información de clientes cuando ya no sea necesaria. Evidencia: calendario, trabajos de borrado, certificados de destrucción y excepciones por legal hold. Probar sobre-retención y finalización de eliminación.

26. Pruebas de controles y monitoreo continuo

Establecer un programa de pruebas mediante revisión de evidencia, validación técnica, muestreo, autoevaluación, pruebas independientes cuando correspondan y monitoreo

continuo. Evidencia: planes, papeles de trabajo, hallazgos y métricas. Ajustar frecuencia según criticidad y tasa de cambio.

27. Gobierno de pruebas de penetración y evaluación de vulnerabilidades

Definir gobierno para pruebas de penetración y evaluaciones de vulnerabilidad conforme a la Regla de Salvaguardas vigente y al riesgo organizacional. Especificar alcance, independencia/competencia, seguimiento de remediación, retest y excepciones. Evidencia: reportes, planes y retests. Revalidar requisitos actuales de la FTC antes de liberar.

28. Reportes a la gerencia y órgano de gobierno

Reportar periódicamente postura de riesgo, deficiencias materiales, incidentes, riesgos de proveedores, remediación, pruebas y cambios del programa a la instancia de gobierno correspondiente. Evidencia: informes, actas y registros de acciones. Probar que asuntos materiales sean escalados y cerrados.

29. Excepciones, aceptación de riesgo y remediación

Usar un proceso controlado que registre justificación, salvaguardas compensatorias, riesgo residual, aprobador, vencimiento y plan de remediación. Evidencia: registro y aprobaciones. Probar excepciones vencidas y extensiones repetidas sin reevaluación.

30. Arquitectura de evidencia y preparación para auditoría

Definir objetos de evidencia por salvaguarda, convenciones, repositorios, retención, cadena de custodia cuando aplique y responsables. Mantener mapeos evidencia-control y diferenciar evidencia operativa de afirmación gerencial. Evidencia: catálogo, matriz y papeles de trabajo. Probar reconstrucción independiente de controles muestreados.

31. Disparadores de cambio, vigilancia de enmiendas y reevaluación

Monitorear enmiendas de la FTC, orientación oficial, desarrollos de enforcement relevantes y cambios organizacionales que afecten aplicabilidad o salvaguardas. Activar reevaluación tras cambios materiales de tecnología, datos, proveedores, productos, modelo de negocio o regulación. Evidencia: registro de vigilancia y evaluaciones de cambio.

32. Localización, QA de artefactos y controles de liberación

Congelar la fuente inglesa exacta antes de localización controlada es-419 y pt-BR. Vincular cada localización a la identidad inglesa congelada y preservar el significado regulatorio sin presentar traducciones no oficiales como texto autoritativo de la FTC. Antes de publicar exigir paridad trilingüe, QA renderizado/páginas, accesibilidad, hashes SHA-256 exactos, staging durable, seguridad de workflows, reverificación de fuentes, publicación del predecesor y reconciliación de catálogo/registro de liberaciones.

Límite controlado de liberación

Este borrador localizado no establece por sí mismo cumplimiento, interpretación legal, aseguramiento de auditoría ni elegibilidad de publicación. Cualquier requisito documentado de revisión humana genuina permanece abierto hasta quedar ligado a los hashes exactos aplicables.